

Министерство образования Республики Беларусь

Учреждение образования
«БЕЛОРУССКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ
ИНФОРМАТИКИ И РАДИОЭЛЕКТРОНИКИ»

Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий

Лабораторная работа №4

по дисциплине «Проектирование защищенных интеллектуальных
информационных систем»

на тему «Безопасность работы удалённых серверов в сети Internet.
Часть 1. Анализ запросов из сети Internet»

Выполнил студент гр. 321701

Ковальчук В. Н.
Самович В. М.

Проверил

Сальников Д. А.

Минск 2026

Цель: получить практические навыки анализа защищённости реального удалённого сервера, доступного из сети Internet по SSH и HTTP(S), на основании данных, накапливаемых системами журналирования в течение нескольких дней естественной эксплуатации.

Задание:

- а) Установить на удалённом сервере веб-сервер и разместить на нём тестовую страницу, доступную из сети Internet.
- б) Настроить систему журналирования на веб-сервере.
- в) Выполнить анализ данных логов различных подсистем, в том числе SSH и веб-сервера удалённого сервера, за несколько дней.
- г) Оформить отчёт о проделанной работе.

Постановка задачи. В качестве удалённого сервера используется виртуальный сервер (VPS) под управлением Ubuntu 24.04 с публичным IP-адресом и доменным именем `test-lab4.work.gd`. В роли веб-сервера выбран Caddy – он раздаёт тестовую страницу (одностраничное приложение на React) по протоколу HTTPS с автоматически выпущенным сертификатом Let's Encrypt. Сервер намеренно оставлен доступным из интернета без дополнительного ограничения (кроме управления по ключу SSH вместо пароля) на несколько дней, чтобы в логах SSH-демона и веб-сервера накопился настоящий фоновый интернет-трафик (автоматические сканеры, попытки подбора пароля и т. п.), а не искусственно смоделированные обращения.

Краткое описание веб-сервера

Caddy – веб-сервер общего назначения, отличительная черта которого – автоматическое получение и продление TLS-сертификатов (протокол ACME, по умолчанию Let's Encrypt) без отдельного инструмента вроде `certbot`: сертификат запрашивается и обновляется самим процессом сервера при старте и по мере истечения срока действия. На сервере `test-lab4.work.gd` Caddy раздаёт статическую сборку одностраничного React-приложения (тестовая страница лабораторной работы), автоматически перенаправляет запросы с HTTP на HTTPS и записывает каждый запрос в структурированный лог в формате JSON (`/var/log/caddy/access.log`) с ротацией по размеру файла. Конфигурация задаётся декларативным `Caddyfile` и хранится в репозитории лабораторной работы (`Lab4.1-WebServer`) отдельно от самого сервера, что позволяет пересоздать развёртывание с нуля.

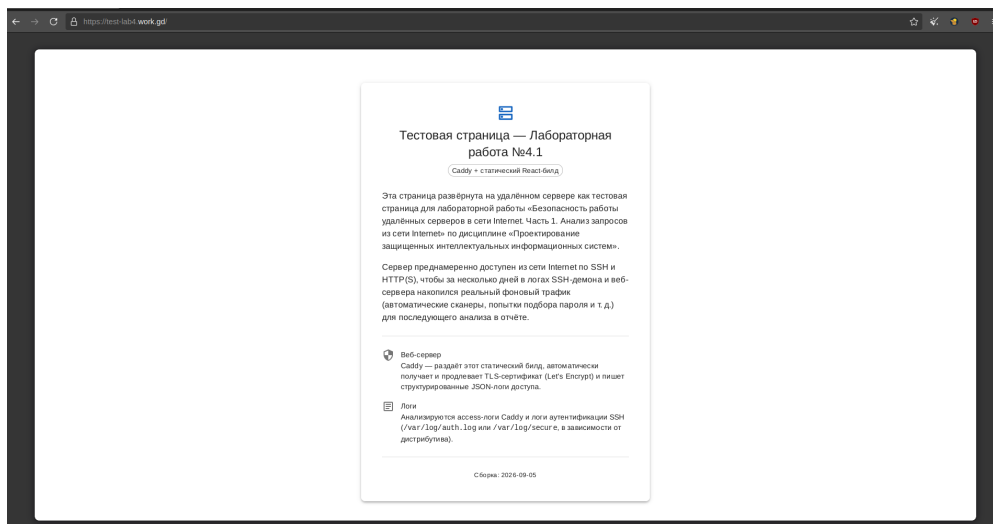


Рисунок 1 – Тестовая страница, открытая в браузере по адресу <https://test-lab4.work.gd/>

Краткое описание анализируемых файлов

– `/var/log/auth.log` – журнал аутентификации ОС (Ubuntu/Debian; на CentOS/RHEL аналогичную роль играет `/var/log/secure`), куда демон `sshd` через `syslog/rsyslog` записывает каждую попытку входа: успешную (`Accepted publickey/password`) и неуспешную (`Failed password`, `Invalid user`), с указанием имени пользователя, IP-адреса источника, времени и способа аутентификации. Это основной источник данных для анализа попыток подбора учётных данных по SSH.

– `/var/log/caddy/access.log` – журнал доступа веб-сервера, одна строка JSON на каждый HTTP(S)-запрос: IP клиента, метод, путь, код ответа, заголовок `User-Agent`, время обработки запроса. Позволяет отличить обращения реальных пользователей от автоматических сканеров и ботов по характерным путям запроса (например, попытки достучаться до путей вроде `/wp-admin`, административных панелей хостинг-провайдеров и т. п., которых на самой странице не существует) и по строке `User-Agent`.

Анализ запросов из сети на SSH сервер и веб-сервер

Раздел будет заполнен после завершения сбора данных за несколько дней эксплуатации сервера. Здесь будут приведены: общее число попыток входа по SSH и их динамика по времени; список наиболее активных источников (IP-адресов/подсетей) и то, что из

этого автоматически заблокировано системой предотвращения вторжений (см. отчёт по лабораторной работе №4.2); наиболее часто перебираемые имена пользователей; статистика запросов к веб-серверу – объём трафика, доля обращений к несуществующим путям, характерные User-Agent сканеров, обнаруженные при первом же запуске сервера (например, сканер LeakIX).

Рекомендации по улучшению безопасности удалённого сервера

а) Запретить удалённый вход суперпользователя (**root**) через SSH (**PermitRootLogin no**) и работать через отдельную учётную запись с повышением привилегий через **sudo** – на момент выполнения лабораторной работы **root** остаётся доступен намеренно, чтобы не исказить статистику попыток входа именно под этой учётной записью.

б) Отключить аутентификацию по паролю (**PasswordAuthentication no**), оставив только вход по публичному ключу – сам подбор пароля тогда теряет смысл вне зависимости от его сложности.

в) Ограничить набор IP-адресов, которым разрешён доступ по SSH (например, через **AllowUsers user@подсеть** или отдельное правило firewall), если круг легитимных источников подключения заранее известен.

г) Установить и настроить систему обнаружения/предотвращения вторжений (IDS/IPS) для автоматической блокировки источников, массово подбирающих пароль или сканирующих сервер – реализовано и подробно разобрано в отчёте по лабораторной работе №4.2.

д) Свести перечень открытых портов к минимально необходимому (22, 80, 443) средствами firewall и логировать заблокированные попытки подключения к остальным портам отдельно.

е) Регулярно анализировать журналы (в идеале – с автоматическим оповещением при превышении порога подозрительной активности), а не только пост-фактум, как в рамках этой лабораторной работы.

Выводы

Раздел будет окончательно сформулирован после анализа данных из раздела «Анализ запросов из сети на SSH сервер и веб-сервер» – семантическая и прагматическая составляющие ниже приведены в виде каркаса и будут дополнены конкретными числами и наблюдениями.

Семантически лабораторная работа должна подтвердить (или опровергнуть) теоретическое утверждение задания о том, что любой сервер с публичным IP-адресом подвергается непрерывному фоновому сканированию и подбору паролей вне зависимости от того, насколько он приметен или содержит ли что-либо ценное для атакующего – сам факт присутствия в интернете уже является достаточным поводом. *[после сбора данных: подтвердить конкретными цифрами – через сколько времени после публикации домена появились первые обращения, сколько уникальных источников набралось за период наблюдения и т. д.]*

С прагматической точки зрения работа должна показать, что настройка журналирования – не разовое действие, а условие, без которого дальнейший анализ и, тем более, лабораторная работа №4.2 (сравнение «до» и «после» установки IDS/IPS) невозможны в принципе: без включённого заранее логирования сравнивать не с чем. *[после сбора данных: указать, какие именно практические решения по результатам анализа логов признаны наиболее эффективными и почему]*